

Cybersecurity Daily Newsletter

Vol. 003 | 2026-07-04 07:00 WIB

Top 5 Highlights

- Microsoft 365 users fall victim to one-in-a-million password spray attack
- ARToken PhaaS exposes EvilTokens' Microsoft 365 phishing toolkit
- Adobe premieres a second Patch Tuesday each month to deliver fixes faster
- Verified X ad spreads Mac malware, while ConsentFix steals Microsoft accounts
- Qilin Dominates Ransomware Market Amid Growing Cybercrime Consolidation

Threat Intelligence (10)

01. ARToken PhaaS exposes EvilTokens' Microsoft 365 phishing toolkit

A new phishing-as-a-service (PhaaS) platform dubbed "ARToken" appears to operate as an affiliate of the EvilTokens phishing platform, giving researchers a glimpse into an extensive toolkit designed to compromise Microsoft 365. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.bleepingcomputer.com/news/security/artoken-phaas-exposes-eviltokens-microsoft-365-phishing-toolkit/>

02. Verified X ad spreads Mac malware, while ConsentFix steals Microsoft accounts

Two new campaigns show how cybercriminals are increasingly relying on social engineering instead of software exploits to compromise devices and accounts.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.malwarebytes.com/blog/news/2026/07/verified-x-ad-spreads-mac-malware-while-consentfix-steals-microsoft-accounts>

03. FBI, Google Take Down NetNut Proxy Network Used by Cyber Threat Actors

The NetNut proxy network and the 'Popa' botnet are known to have infected devices with variants of Mirai DDoS botnets

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.infosecurity-magazine.com/news/fbi-google-take-down-netnut-proxy/>

04. [+24h Old] FBI Seizes NetNut Proxy Platform, Popa Botnet

The Federal Bureau of Investigation (FBI) said today it worked with industry partners to seize hundreds of domains associated with NetNut, a sprawling residential proxy service operated by the publicly-traded Israeli company Alarum Technologies [NASDAQ: ALAR]. The action comes roughly two weeks after KrebsOnSecurity published findings from multiple security...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://krebsonsecurity.com/2026/07/fbi-seizes-netnut-proxy-platform-popa-botnet/>

05. [+24h Old] OpenBlow Multiple Deanonymization Vulnerabilities

Posted by Red Nanaki via Fulldisclosure on Jul 02 OpenBlow Multiple Deanonymization Vulnerabilities Summary A production deployment was observed (HTTP archive of a full, real whistleblower submission) to route its anonymous reporting flow through Google. The intake CAPTCHA is Google reCAPTCHA, enforced as a mandatory, server-validated gate on report submiss...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://seclists.org/fulldisclosure/2026/Jul/15>

06. [+24h Old] Whistlelink: Site-access password exposed in web server access logs via GET query string

Posted by Red Nanaki via Fulldisclosure on Jul 02 Whistlelink: Site-access password exposed in web server access logs via GET query string Severity: CRITICAL SUMMARY The Whistlelink reporting portal protects optionally-enabled, password-gated whistleblowing sites with a site-access password. When a visitor unlocks such a site, the client validates the passw...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://seclists.org/fulldisclosure/2026/Jul/14>

07. [+24h Old] APPLE-SA-06-29-2026-3 Safari 26.5.2

Posted by Apple Product Security via Fulldisclosure on Jul 02 APPLE-SA-06-29-2026-3 Safari 26.5.2 Safari 26.5.2 addresses the following issues. Information about the security content is also available at <https://support.apple.com/en-us/127685...>

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://seclists.org/fulldisclosure/2026/Jul/13>

08. [+24h Old] APPLE-SA-06-29-2026-2 macOS Tahoe 26.5.2

Posted by Apple Product Security via Fulldisclosure on Jul 02 APPLE-SA-06-29-2026-2 macOS Tahoe 26.5.2 macOS Tahoe 26.5.2 addresses the following issues. Information about the security content is also available at <https://support.apple.com/en-us/127595...>

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://seclists.org/fulldisclosure/2026/Jul/12>

09. [+24h Old] APPLE-SA-06-29-2026-1 iOS 26.5.2 and iPadOS 26.5.2

Posted by Apple Product Security via Fulldisclosure on Jul 02 APPLE-SA-06-29-2026-1 iOS 26.5.2 and iPadOS 26.5.2 iOS 26.5.2 and iPadOS 26.5.2 addresses the following issues. Information about the security content is also available at <https://support.apple.com/en-us/127594...>

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://seclists.org/fulldisclosure/2026/Jul/11>

10. [+24h Old] Asterisk Security Release 23.4.1

Posted by Asterisk Development Team via Fulldisclosure on Jul 02 The Asterisk Development Team would like to announce security release Asterisk 23.4.1. The release artifacts are available for immediate download at <https://github.com/asterisk/asterisk/releases/tag/23.4.1> and <https://downloads.asterisk.org/pub/telephony/asterisk> Repository: <https://github.com...>

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://seclists.org/fulldisclosure/2026/Jul/7>

Latest Vulnerabilities (10)

01. Microsoft 365 users fall victim to one-in-a-million password spray attack

Microsoft users have been hit by a massive, automated password spray attack. Among those targeted by the attack were clients of security company Huntress. It reported that the attackers made 81 million attempts to log into its customers' accounts between June 12 and 26 - and succeeded in at least 78 cases. And that's just the attacks on Microsoft account ho...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoononline.com/article/4192819/microsoft-365-users-fall-victim-to-one-in-a-million-password-spray-attack.html>

02. Adobe premieres a second Patch Tuesday each month to deliver fixes faster

Adobe will now issue security patches for its products twice as often to deal with the increasing pace of software vulnerability discovery and exploitation. This follows Oracle's decision to increase its quarterly patch program to a monthly one. Adobe issues patches on the second Tuesday of each month, as do Microsoft and SAP. Starting in July, it will also...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4192789/adobe-premieres-a-second-patch-tuesday-each-month-to-deliver-fixes-faster.html>

03. New CitrixBleed-like NetScaler flaw sees exploit attempts in the wild

Citrix NetScaler appliances have been a constant target for attackers in recent years, most recently through an information leak vulnerability dubbed CitrixBleed 3, the latest in a series of NetScaler memory overreads going back to 2023. This week, Citrix patched yet another CitrixBleed-like vulnerability and there are signs of in-the-wild exploitation already...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4192741/new-citrixbleed-like-netscaler-flaw-sees-exploit-attempts-in-the-wild.html>

04. Organizations struggle to prioritize known cyber risks

Organizations collect more cyber risk data than ever, with many still struggling to build a unified view of their exposure. The latest State of Threat Management report from Filigran found that security teams continue to work across disconnected tools, leaving important context spread across multiple systems. Cloud infrastructure, on-premises environments,...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.helpnetsecurity.com/2026/07/03/cyber-risk-exposure-report/>

05. [+24h Old] Apple Reverses Age-Old Patch Policy to Keep Up With AI

Expect more compressed patching cycles from Apple going forward, as attackers leverage artificial intelligence to reduce time to exploit.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.darkreading.com/cybersecurity-operations/apple-patch-policy-ai>

06. [+24h Old] pwnlift: symlink following and TOCTOU in privileged upload handler allow arbitrary file write as root

Posted by Greg via Fulldisclosure on Jul 02 1. Advisory information ----- Title: Symlink following and TOCTOU in pwnlift upload handler allow arbitrary file write as root
Advisory: <https://github.com/GregDurys/security-advisories> GHSA: GHSA-2v7v-rhpw-m9w4 CVE: CVE-2026-56815 Class: CWE-59 (Improper Link Resolution Before File Access), CWE-...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Jul/10>

07. [+24h Old] [KIS-2026-12] Control Web Panel <= 0.9.8.1224 (userRes) SQL Injection Vulnerability

Posted by Egidio Romano on Jul 02 -----
Control Web Panel ----- [-] Software Link: <https://control-webpanel.com> [-] Affected Versions: Version 0.9.8.1224 and prior versions.
[-] Vulnerability Description: User input passed through...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Jul/9>

08. [+24h Old] [fulldis] CVE-2026-58451 - Horde Groupware IMP path traversal vuln

Posted by [evan via Fulldisclosure on Jul 02 this is my first time sending to a mailing list so ive chosen something easy. here goes: Summary: Horde Groupware's IMP Webmail solution contains a path traversal/local file inclusion vulnerability which could be exploited to escalate privileges or bypass authentication (through CSRF if unauthenticated). the vuln...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Jul/8>

09. [+24h Old] Samsung Galaxy Buds - Zero-Click HFP/A2DP Takeover via L2CAP Session Preemption (Vendor Response: Working as Intended)

Posted by 490h3fqwomf via Fulldisclosure on Jul 02 Hello Full Disclosure, The following publicly available research describes a Bluetooth attack against Samsung Galaxy Buds that leverages connection arbitration behavior between HFP and A2DP profiles to preempt an active audio session. Title: Zero-Click HFP/A2DP Takeover via L2CAP Session

Preemption Exploiti...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Jul/5>

10. [+24h Old] Apple's Hide My Email doesn't hide it very well

A year ago a researcher found a vulnerability in Apple's Hide My Email feature and now he's tired of waiting for a fix.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.malwarebytes.com/blog/news/2026/07/apples-hide-my-email-doesnt-hide-it-very-well>

Data Breach & Cybercrime (10)

01. Qilin Dominates Ransomware Market Amid Growing Cybercrime Consolidation

The ransomware landscape is reconsolidating around major players, with Qilin emerging as the leading RaaS operation, researchers say

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/qilin-dominates-ransomware-market/>

02. Warning Over "Industrialized" Cyber-Attacks After Ransomware Gang Partners With TeamPCP

Researchers warn that collaboration could lead to "unprecedented" ransomware attacks, as FBI also issues warning

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/industrialized-cyberattacks/>

03. [+24h Old] Aussies Face Reduced Cybercrime Risk, as Pressure Shifts to SMBs

Improved institutional safeguards and stricter regulations have pushed the burdens of protection and risk reduction on to Australian businesses.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.darkreading.com/cybersecurity-analytics/aussies-face-reduced-cybercrime-risk-pressure-shifts-smbs>

04. [+24h Old] FortiBleed Actors Collaborating With Inc, Lynx Ransomware Gangs

After gaining a foothold in thousands of Fortinet firewalls, the attackers are starting to monetize that access, and are also piling on a Nextcloud zero-day bug.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.darkreading.com/threat-intelligence/fortibleed-actors-inc-lynx-ransomware-gangs>

05. [+24h Old] Whistleblowersoftware.com: confidentiality and anonymity leakage to third parties

Posted by Red Nanaki via Fulldisclosure on Jul 02 Whistleblowersoftware.com: confidentiality and anonymity leakage to third parties ## Summary The anonymous reporting flow on `whistleblowersoftware.com` encrypts report text end-to-end in the browser but does not extend the same guarantee to attachments and exposes the reporter's network identity and timing...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://seclists.org/fulldisclosure/2026/Jul/16>

06. [+24h Old] Ransomware Thugs Masquerade as Interpol to Entice Small Biz

The ransomware campaign relies on basic social engineering and stretches across multiple regions, including the US, Europe, Middle East, and elsewhere.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.darkreading.com/cyberattacks-data-breaches/attackers-use-interpol-lure-target-small-businesses>

07. [+24h Old] Scattered Spider suspect extradited over \$8 million ransom scheme

A suspected Scattered Spider member has been extradited to the United States to face charges linked to cyberattacks against U.S. companies, including the breach of a luxury

jewelry retailer that led to an \$8 million cryptocurrency ransom demand after attackers stole company data. The retailer's security team removed the attackers from its network before any...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.helpnetsecurity.com/2026/07/02/scattered-spider-criminal-group-suspect-extradited/>

08. [+24h Old] New iboss platform gives organizations instant visibility into AI tools and usage

iboss has launched the AI Security Platform, a new service that gives any organization visibility into the AI tools its people are using, free of charge. Signup is instant, deployment takes an afternoon, and a complete AI footprint appears within hours. Organizations that want to go beyond visibility can upgrade on the same platform to enforce AI policy, pr...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/07/02/iboss-ai-security-platform/>

09. [+24h Old] Alleged Scattered Spider Member Extradited to US

A teenager accused of hacking as part of Scattered Spider has been arrested

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.infosecurity-magazine.com/news/scattered-spider-member-extradited/>

10. [+24h Old] Medtronic notifies customers impacted by ShinyHunters data breach

Healthcare device firm Medtronic is notifying affected customers about a data breach that exposed their personal data to an unauthorized third party. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/medtronic-notifies-customers-impacted-by-shinyhunters-data-breach/>